Hướng dẫn làm bài tập nhóm

An toàn và bảo mật thông tin

1. Chọn đề tài

- Mỗi nhóm chọn một đề tài trong danh sách gợi ý dưới đây, hoặc tự đề xuất một hệ mã khác nhưng phải nằm trong phạm vi cho phép và được giảng viên duyệt trước khi đăng ký.
- Phạm vi đề tài: **các hệ mã hiện đại, tính từ mã dòng A5/1 và RC4 trở về sau** — gồm phần mã hoá đối xứng hiện đại (Chương 2), mã hoá khoá công khai (Chương 3) và hàm băm – chữ ký điện tử (Chương 4). Không làm đề tài về mã cổ điển (Caesar, bảng chữ đơn, Playfair, Vigenère, Rail Fence, hoán vị cột).
- Nếu hệ mã được trình bày ở hai phiên bản — bản thu nhỏ dùng để dạy (TinyA5/1, TinyRC4, TinyDES) và bản đầy đủ (A5/1, RC4, DES) — thì nhóm phải tìm hiểu và cài đặt **cả hai phiên bản**.
- Hạn cuối chốt đề tài và điền vào **LINK ĐĂNG KÝ ĐỀ TÀI**
- Yêu cầu: **1 đề tài tối đa có 2 nhóm đăng ký**
- Danh sách đề tài gợi ý:
    - **Nhóm A — Mã hoá đối xứng hiện đại (Chương 2, mục 3)**
        - Hệ mã dòng A5/1 — làm cả TinyA5/1 và A5/1 đầy đủ (ba thanh ghi 19 + 22 + 23 bít, quy tắc quay theo hàm chiếm đa số, dùng trong mạng GSM).
        - Hệ mã dòng RC4 — làm cả TinyRC4 và RC4 đầy đủ (mảng S 256 byte, giai đoạn khởi tạo và giai đoạn sinh số, từng dùng trong WEP và SSL).
        - Hệ mã khối DES — làm cả TinyDES và DES đầy đủ (16 vòng Feistel, khoá 56 bít, hoán vị khởi tạo/kết thúc, tám hộp S).
        - Double DES và Triple DES — dựa trên DES, kèm phân tích tấn công gặp nhau ở giữa (meet-in-the-middle) và lý do 2DES không mạnh như kỳ vọng.
        - Chuẩn mã hoá nâng cao AES — cấu trúc mạng SPN, các phép SubBytes, ShiftRows, MixColumns, AddRoundKey và thuật toán sinh khoá vòng.
    - **Nhóm B — Mã hoá khoá công khai (Chương 3)**
        - Hệ mã ba lô Knapsack (hệ mã MHK) — bài toán xếp ba lô, véc tơ siêu tăng, cách sinh khoá công khai từ khoá riêng và lý do hệ mã này đã bị phá.
        - Hệ mã RSA — kèm các thuật toán nền: Euclid mở rộng, tìm phần tử nghịch đảo theo modulo, thuật toán bình phương và nhân, kiểm tra số nguyên tố Miller – Rabin.
        - Trao đổi khoá Diffie – Hellman — bài toán logarit rời rạc, kèm minh hoạ tấn công người đứng giữa (man-in-the-middle) và cách phòng chống.
    - **Nhóm C — Hàm băm và chữ ký điện tử (Chương 4)**
        - Hàm băm MD5 — cấu trúc Merkle – Damgård, bốn vòng 64 bước, và vì sao MD5 đã bị loại khỏi các ứng dụng bảo mật.
        - Hàm băm SHA — cài đặt SHA-1 và một biến thể của SHA-2 (khuyến nghị SHA-256), so sánh hai thế hệ.

        - Hệ chữ ký điện tử RSA — ký trên giá trị băm của thông điệp, kiểm tra chữ ký, phân tích tính chứng thực và tính không chối bỏ.
        - Chuẩn chữ ký điện tử DSS/DSA — sinh bộ tham số p, q, g, thuật toán ký và thuật toán kiểm tra, so sánh với chữ ký RSA.
    - Nhóm có thể tự đề xuất đề tài khác cùng mức độ, ví dụ ChaCha20, mật mã đường cong elliptic (ECC/ECDSA), SHA-3/Keccak hoặc HMAC, nhưng phải được duyệt trước hạn đăng ký.

2. Yêu cầu thực hiện

- Công việc của mỗi nhóm gồm bốn phần: **tìm hiểu hệ mã, thực thi (cài đặt) hệ mã và chạy demo, viết báo cáo, thuyết trình**.
- **Tìm hiểu hệ mã:**
    - Bối cảnh ra đời: tác giả, năm công bố, vấn đề mà hệ mã giải quyết, hệ mã đã và đang được dùng ở đâu trong thực tế.
    - Mô tả đầy đủ thuật toán: tham số đầu vào, cách sinh khoá, quá trình mã hoá, quá trình giải mã. Có sơ đồ khối do nhóm tự vẽ, không chụp lại ảnh trong slide.
    - Trình bày một ví dụ tính tay đầy đủ từng bước trên phiên bản thu nhỏ (hoặc trên bộ số nhỏ đối với hệ khoá công khai). Kết quả tính tay phải khớp với chương trình nhóm cài đặt.
    - Phân tích độ an toàn: kích thước không gian khoá, các kiểu tấn công đã biết, chi phí tấn công, hệ mã hiện còn được khuyến nghị sử dụng hay đã bị loại bỏ và vì sao.
    - So sánh với ít nhất một hệ mã cùng loại đã học (về nguyên lý, tốc độ, độ an toàn, phạm vi ứng dụng).
- **Thực thi hệ mã (cài đặt):**
    - Nhóm tự cài đặt thuật toán từ đầu. **Không dùng thư viện mật mã có sẵn cho phần lõi** (ví dụ không gọi hashlib.md5, Crypto.Cipher.DES, openssl); thư viện chuẩn chỉ được dùng để đối chiếu kết quả.
    - Đề tài có hai phiên bản thì cài đặt cả hai. Phiên bản thu nhỏ phải tái hiện đúng ví dụ đã học trên lớp — đây là căn cứ đầu tiên để chấm tính đúng đắn của chương trình.
    - Ngôn ngữ lập trình tự chọn (Python, C/C++, Java, JavaScript, C#, ...).
    - Có đủ cả hai chiều: mã hoá và giải mã. Với hàm băm là tính giá trị băm và kiểm tra toàn vẹn; với chữ ký điện tử là ký và kiểm tra chữ ký. Giải mã phải khôi phục đúng bản rõ ban đầu.
    - Có bộ kiểm thử: ít nhất ba ca kiểm thử do nhóm tự viết, cộng với đối chiếu bằng bộ test vector chuẩn (NIST, RFC) hoặc với thư viện chuẩn, và in ra được kết quả đối chiếu.
    - Mã nguồn chia module rõ ràng, có chú thích, tách phần thuật toán khỏi phần giao diện.
- **Chạy demo:**
    - Chương trình chạy được trực tiếp: nhập bản rõ và khoá, hiện bản mã, rồi giải mã ngược lại đúng bản rõ ban đầu.
    - Với phiên bản thu nhỏ, in ra được các bước trung gian (nội dung thanh ghi, dãy số sinh, dãy S, khoá con, kết quả từng vòng...) để minh hoạ thuật toán khi thuyết trình.

    - Demo trên dữ liệu thật, không chỉ vài ký tự: mã hoá một tệp văn bản hoặc một tệp ảnh nhỏ rồi giải mã lại.
    - Khuyến khích: có giao diện (CLI có menu, web hoặc GUI); đo thời gian chạy theo kích thước dữ liệu; minh hoạ một tình huống tấn công đã nêu trong báo cáo (dùng lại dòng khoá, va chạm MD5, người đứng giữa trong Diffie – Hellman...).
    - Thời lượng demo trên lớp: 5 – 7 phút cho mỗi nhóm, chạy trực tiếp; nên chuẩn bị video dự phòng phòng khi máy lỗi.
- **Báo cáo:**
    - Bố cục gợi ý: Mở đầu → Cơ sở lý thuyết → Phân tích thuật toán → Cài đặt và kiểm thử → Kết quả demo và đánh giá → Kết luận → Tài liệu tham khảo.
    - Trích dẫn đầy đủ tài liệu tham khảo. Nếu có tham khảo mã nguồn bên ngoài, phải nói rõ phần nào tham khảo và phần nào nhóm tự viết.
    - Có bảng phân công công việc và tỉ lệ đóng góp của từng thành viên, được cả nhóm xác nhận.

3. Nộp bài

- Yêu cầu nộp bài:
    - File mã nguồn (khuyến khích dùng GitHub và thể hiện được đóng góp của từng thành viên qua lịch sử commit), kèm tệp README hướng dẫn cài đặt và cách chạy chương trình.
    - File báo cáo (theo mẫu khoá luận của khoa CNTT và lược bỏ một số phần như lời cam đoan, ...: LINK).
    - File slide thuyết trình.
    - Video demo 3 – 5 phút (khuyến khích, dùng làm bản dự phòng khi demo trực tiếp gặp sự cố).
- **Thời gian nộp bài: ...**
- **Thư mục để nộp bài: LINK**

4. Tiêu chí đánh giá

- Tìm hiểu và báo cáo (đầy đủ, chính xác, có phân tích an toàn): 30%
- Cài đặt hệ mã (đúng, đủ hai phiên bản nếu có, có kiểm thử đối chiếu): 30%
- Demo và trả lời câu hỏi khi bảo vệ: 25%
- Trình bày, phân công và tiến độ: 15%
- Điểm của từng thành viên có thể khác điểm chung của nhóm, căn cứ vào phần việc đã làm và phần trả lời câu hỏi khi bảo vệ.

5. Lưu ý khác

- Nhóm cần đảm bảo sản phẩm nộp đúng hạn và đúng định dạng yêu cầu.
- Các đề tài trùng quá số lượng cho phép sẽ được tính theo thời gian đăng ký trước.
- Một số đề tài thuộc Chương 3 và Chương 4 sẽ được học ở các tuần sau. Nhóm chọn những đề tài này cần chủ động đọc trước tài liệu, không chờ đến khi học trên lớp mới bắt đầu.
- Được phép dùng công cụ AI để hỗ trợ, nhưng phải ghi rõ đã dùng vào việc gì, và mọi thành viên phải giải thích được toàn bộ mã nguồn của nhóm khi bảo vệ.
- Khuyến khích các nhóm đầu tư vào phần demo trực quan và phần phân tích độ an toàn — đây là hai phần tạo nên khác biệt giữa các nhóm.